

DISCUSSION PAPER

Secure cross-company communication with OPC UA

Imprint

Publisher

Federal Ministry for Economic
Affairs and Energy (BMWi)
Public Relations
11019 Berlin
www.bmwi.de

Text and editing

Plattform Industrie 4.0
Bertolt-Brecht-Platz 3
10117 Berlin

Design and production

PRpetuum GmbH, Munich

Status

March 2019

Photos and illustrations

Getty Images – gvinpin (title)
Getty Images – Busakorn Pongparnit (p. 3)
Getty Images – Andriy Onufriyenko (p. 5)
Getty Images – skynesher (p. 7)
Getty Images – Fertnig (p. 11)
Getty Images – Bloom Productions (p. 22)

This brochure is published as part of the public relations work of the Federal Ministry for Economic Affairs and Energy. It is distributed free of charge and is not intended for sale. The distribution of this brochure at campaign events or at information stands run by political parties is prohibited. No political party-related information or advertising may be inserted in, printed on or affixed to this publication.

This and other publications are available from:
Federal Ministry for Economic Affairs and Energy
Public Relations
E-mail: publikationen@bundesregierung.de
www.bmwi.de

Central procurement service:
Telephone: 030 182722721
Fax: 030 18102722721



Table of contents

1	Introduction	3
1.1	Content and aim of this discussion paper	3
1.2	Classification in the life cycle/RAMI4.0	4
1.3	The meaning of OPC UA	4
2	Security	5
2.1	Risk-based approach	5
2.2	Security in communication	6
2.3	Stakeholders	6
3	“Condition monitoring and parameterisation” application scenario	7
3.1	Operator	8
3.2	Service provider	9
3.3	Requirements for the solution approaches	10
4	Solution approaches	11
4.1	Solution approach: direct connection	12
4.1.1	Variant A: client to server	12
4.1.2	Variant B: reverse-connect	14
4.1.3	Process/prerequisites	15
4.1.4	Evaluation	15
4.2	Solution approach: aggregating server	16
4.2.1	Scenario A: the operator provides and manages an aggregating server.	17
4.2.2	Scenario B: the service providers set up their own aggregating servers at the operator’s site.	19
4.2.3	Evaluation and comparison of scenarios	20
4.3	Comparison of solution approaches	21
5	Summary and outlook	22
6	Attachment	23
6.1	Glossar	23
6.2	List of figures	23
6.3	Bibliography	24
	Editorial team	25



1 Introduction

With innovative concepts and approaches, Industrie 4.0 creates completely new opportunities for cooperation – particularly at a technical level. People, machines and products interact, exchange data and information and correspond all the time. It does not matter whether communication is conducted with a machine in the same factory hall or with a plant in a factory on the other side of the world, exceeding the limits of trust. But this only works if technical communication mechanisms ensure that Industrie 4.0 components (assets) can contact each other securely and interoperably (1) and thus facilitate trust beyond company boundaries.

1.1 Content and aim of this discussion paper

The aim of this discussion paper is to highlight the requirements for the safe use of OPC UA for communication in Industrie 4.0 scenarios, to present implementation options and to identify discussion points. In the discussion paper “Sichere Implementation von OPC UA für Betreiber, Integratoren und Hersteller” (Safe implementation of OPC UA for operators, integrators and manufacturers) (2), the integration of a machine into the infrastructure of an operator was considered over its entire life cycle by way of example. This discussion paper addresses cross-company use by way of the example of an application scenario. The involvement of several companies makes it necessary to harmonise the security requirements of the various stakeholders, as shown in the technical overview “Sichere un-

ternehmensübergreifende Kommunikation” (Secure cross-company communication) (3) are described.

The aim is to provide stakeholders, operators and service providers with concrete information on necessary functions and measures and to describe best practices. At the same time, the analysis is intended to show the extent to which the implementation of the security measures will result in even more far-reaching requirements, which will require additions to the OPC UA standard or to existing toolkits and products. This approach improves consistency and interoperability.

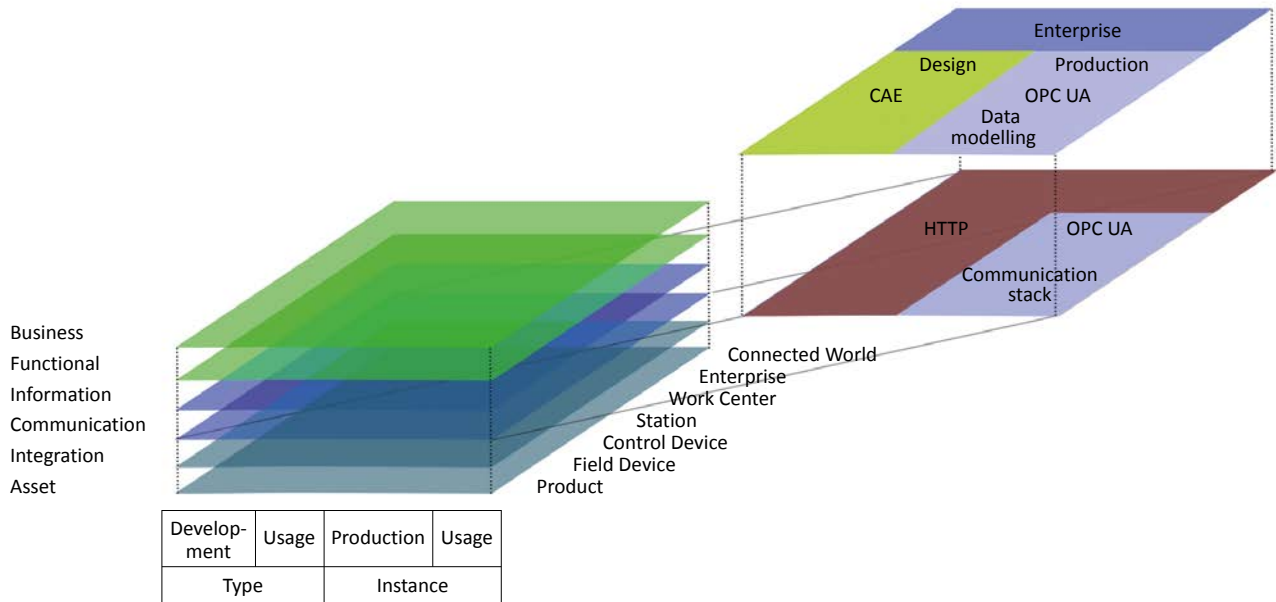
This paper is based on the OPC UA standard, version 1.04¹, which offers significant enhancements, especially in the area of security. However, it can be assumed that implementations and development tools available on the market do not yet meet this standard. One aim of this paper is to support providers and users in the transition.

The solution approaches considered refer to the client-server model of OPC UA. Alternative solution approaches could be implemented with the Publish-Subscribe (PubSub) model. The PubSub concept will be considered in a follow-up publication. A final evaluation of the best implementation variant from the point of view of the security requirements can only be made at the end of these further considerations.

The paper is aimed at the technically knowledgeable reader, ideally with knowledge of the OPC UA application.

1 <https://opcfoundation.org/developer-tools/specifications-unified-architecture>

Figure 1: Exemplary consideration of communication relationships on the communication and information layer in RAMI4.0



1.2 Classification in the life cycle/RAMI4.0

Figure 1 shows the three areas Engineering/Design, Production and Enterprise in RAMI4.0, whose communication requirements differ significantly. As a consequence, it is foreseeable that correspondingly different technical solutions and protocols will be used.

- Individual devices and systems (“instances”) communicate with each other in the production environment. The systems in the production environment are mostly mission critical for the operators and exchange process-related data. Plattform Industrie 4.0 expects and supports the use of OPC UA as the architecture with the associated communication protocols.
- In the area of enterprise communication and overarching value creation networks, different requirements must be met with regard to the various IT protection goals.
- In the area of engineering, i.e. the treatment of “types”, other requirements must be met. Data sets can be very detailed and large here. Depending on the process, the design and development processes are also longer term.

The “Condition Monitoring and Parameterisation” application scenario described in this paper re-fers to the area of application in the production environment and is therefore implemented using OPC UA.

1.3 The meaning of OPC UA

OPC UA (OPC² Unified Architecture) is an architecture for the description and exchange of machine data. In this respect, OPC UA is more than just a communication protocol – the architecture also includes data models and interaction concepts. OPC has been successfully used in automation technology for a long time. The further development of OPC UA today has broad-base support and was included in the Plattform Industrie 4.0 implementation strategy (4) as an important technology and is part of the “Kriterien für Industrie 4.0-Produkte” (Criteria for Industrie 4.0 Products) of the ZVEI (5).

2 OPC: Originally “OLE for Process Control”, today “Open Platform Communications”.



2 Security

Information security measures serve to protect corporate assets and comply with legal requirements. The main protection objectives are as follows:

- Confidentiality
- Integrity
- Availability

Further protection goals are used in a supplementary or supportive manner:

- Authenticity
- Binding force
- Non-repudiation

Availability is usually a statistical value for failure or recovery, such as one hour per year.

The term reliability is also used in the area of production: reliability considers the freedom from faults. In a physical process, a single fault of 10 seconds can also have relevant effects that could not be statistically assessed on average.

2.1 Risk-based approach

In order to determine the protection goals to be achieved or the measures to be derived from them, the company assets must be determined and the threats affecting them described. Based on this, hazards and risks can be identified and evaluated. A particular challenge here is that the risk is calculated from the maximum damage and the probability of occurrence. However, the probability of occurrence is difficult to grasp due to constantly changing hazards. Influencing factors here are the motivation of attackers as well as the discovery of security gaps that cannot be mapped in classic risk management concepts.

- A classification of the protection requirements (e.g. public, internal, confidential, strictly confidential) is therefore used in the ISO 27001 standard commonly used in the corporate environment (6) to assist in risk assessment and the development of the catalogue of measures.
- The IEC 62443 series of standards developed for automation (7) additionally uses an attacker model to specify security levels for automation systems and components based on this model.

2.2 Security in communication

In cross-company cooperation between service providers and the company, process data and parameterisation are exchanged in the case under consideration. The service providers operate IT systems here that can also be located in a cloud. The systematics of the service providers should be based on the ISO 27001 (6) orientation. A special characteristic for the secure operation of cloud services is ISO 27017 (8). Production systems are involved on the operator side so that an information security management system based on IEC 62443 (7) should be taken as a basis.

In many areas, the approach for security deals with the prevention of security incidents through appropriate measures. However, 100% protection is not possible, so that the corresponding standards (both ISO 27001 and IEC 62443 and others) always also address the areas of detection (detection of attacks) and reaction (countermeasures).

In particular, the cross-company communication of process parameters and the cross-company parameterisation of systems (or parts thereof) pose various challenges for safeguarding the three essential security objectives of confidentiality, integrity and availability, as well as the related objectives of authenticity, binding force and non-repudiation. Therefore, when designing communication, care must be taken to ensure that possible attacks are already structurally prevented. Likewise, it must also be possible to map security requirements resulting from the above-mentioned security standards (e.g. the principle of zones and conduits) in cross-company communication. This paper therefore deals with various communication options, each of which has advantages and disadvantages for achieving these security objectives.

2.3 Stakeholders

Information security always considers a stakeholder and its corporate assets, which are treated in accordance with its relevant protection goals and risk assessment. Where the interests of different stakeholders are concerned, the same risk may therefore be assessed differently. To compensate for this, agreements between the stakeholders are necessary (confidentiality agreements, service level agreements, supplier management), because otherwise risks cannot be assessed and taken into account in a balanced way. This negotiation of corresponding contracts is an essential compo-

nent of relevant standards, and is described, for example, in ISO 27036 “Information security for supplier relationships” (9). This paper makes a fundamental distinction between two stakeholders:

- a) An operator operates a machine or plant. It is assumed that the operator operates several plants or machines.
- b) A service provider who takes over tasks for the operator, such as monitoring parameters or parameterising individual plants or plant components. It is assumed that the service provider has only limited access to the infrastructure of the operator and that the service provider does not fully manage the operation of the operator’s facilities.

The measures discussed in the following are aimed at reducing the risk for the operator by reducing

- a) misconduct on the part of the service provider

or

- b) attacks by third parties.

The interests of the service provider are also considered when it comes to the protection of his own company secrets or the protection of the infrastructure provided by the service provider.

It is assumed that the network of the operator and the network of the service provider(s) represent different security domains. A security domain is a technologically, organisationally or spatially related area with uniform security requirements and/or uniform security administration. In many companies today at least the office area/IT and production area are separate security domains. Special caution is required as information moves across the boundaries of security domains in order to maintain the confidentiality, integrity and availability of information and processes.



3 “Condition monitoring and parameterisation” application scenario

An operator has different machines in use in one or more plants. These machines and plants can be divided into different groups both functionally and from a security point of view. This structure is usually referred to as a zone. Devices within a zone can communicate with each other without major restrictions, while communication across zones must be clearly defined and regulated. Common ways to create zones are to separate a network into different subnetworks or to assign devices to different virtual LANs (VLANs). The transitions (so-called conduits) between the zones are usually realised by configurable packet filters such as firewalls. In the following, it is assumed that an operator has divided his network into different zones and that one or more firewalls must be passed through when communicating with a device in a zone. In this scenario, one or more service providers have access to the machines within the zones.

The service provider offers the operator the services “condition monitoring” and “parameterisation of the machine” (see Figure 2). These services are intended to increase the effectiveness and/or efficiency of operator production, for example by reducing wear on the tools or avoiding machine failure.

For condition monitoring, the service provider requires continuous read access to the process data. For occasional parameterisation, the service provider requires occasional write access to adapt parameters of the machine.

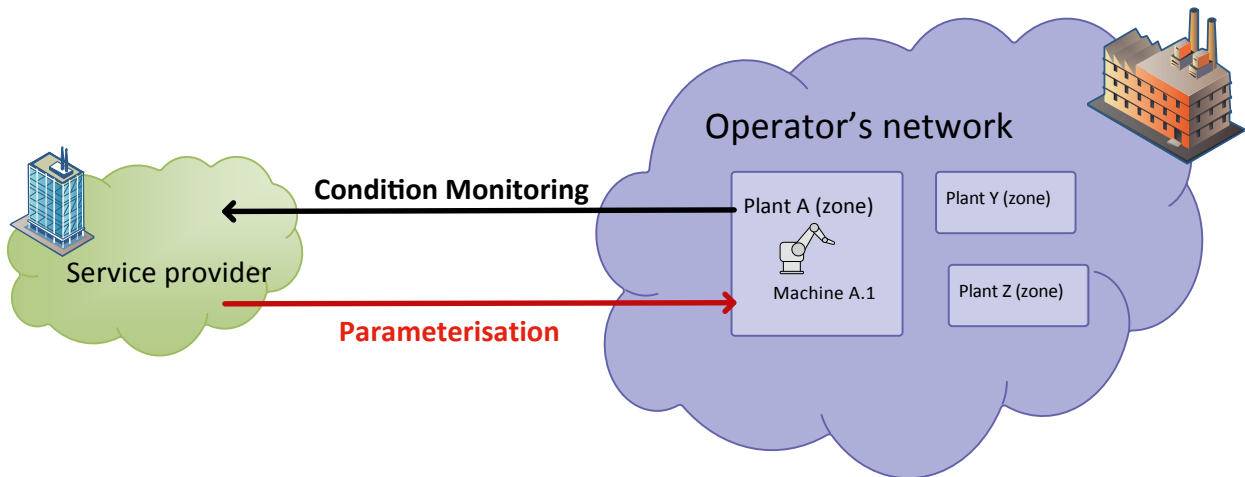
Typical quality and productivity data is relevant for condition monitoring. These include for example

- a) Data from the process, such as temperatures, speeds, torques, etc.
- b) Data on the process result, such as dimensional accuracy, quantities, etc.

Configurations, characteristic curves and set points are relevant for parameterisation. The variable parameters must be contractually defined beforehand.

The security requirements for communication are described in the following from the point of view of both operators and service providers.

Figure 2: „Condition Monitoring and Parameterisation“ application scenario



3.1 Operator

The operator is responsible for the operation of the machine. In the scenario, the operator is faced with the threats listed in the Table 1 where the criminal energy of an attacker is correspondingly high. Internal offenders who are employed by the service provider can also be seen as attackers. Any conduct of the service provider which contradicts the con-

tractual agreements between the operator and the service provider can also be regarded as an attack in this sense.

In principle, further threats can be identified, but they are not considered in this document and are therefore not listed in the table.

Table 1: Operator – application scenario and threats

Application scenario	Threat
Condition monitoring	Service provider can gain unauthorised access to the operator's data.
	External attackers use the service provider unnoticed to gain access.
	The data can be transmitted unencrypted (due to incorrect configuration) and thus spied on by unauthorised persons.
Parameterisation	The availability or operational safety of the machine can be limited or reduced by faulty, unauthorised, manipulated or intentionally faulty parameterisation.
	In the event of faults or problems, it is important for the operator to be able to trace previous changes to the machine in order to find the cause.
	Activities during parameterisation may not be traceable afterwards.

Some of the described threats can be addressed with the available technical means of OPC UA. The OPC UA security policies (with the exception of the security policy “None”) ensure that hash and encryption algorithms are used in communication. It should be noted here that the state of the art is evolving and new algorithms are being added and old algorithms should no longer be used. This is illustrated in the standard by the addition and discontinuation of policies.

The data stored in the machine can, for example, be information on the machine’s usage or specific knowledge of the operator. It is also possible that personal data is involved which is subject to data protection. Under certain circumstances, data may not be transferred at all or additional contractual regulations may be necessary.

Parameterisation risks arise from incorrect or manipulated data. These can be transmitted to the machine, for example, by an unauthorised person or an unauthorised system. The retransmission of data that has been falsified during transmission is ensured by the underlying protocols. The use of the OPC UA mode “Sign” (and also “Sign and Encrypt”) adds a further security layer to the transmission, which reliably excludes not only random errors but also intentional manipulation.

Since the operator is responsible for the machine, he must have control of the machine and know the operating condition of the machine. This is closely linked to operational safety.

Clear regulations are therefore essential for the parameterisation by the service provider. Operators and service pro-

viders must explicitly agree which parameters may be changed. In addition, depending on the extent of the parameterisation, its effect on the security of the system must also be taken into account.

If an incident occurs, it is important that previous operations can be traced in order to determine the causes if necessary.

3.2 Service provider

In this scenario, the service provider is confronted with the threats listed in Table 2 if the attacker’s criminal energy is correspondingly high. As with the operator, both internal offenders and external attackers can be considered here. Similarly, any behaviour of the service provider that contradicts the contractual agreements is to be considered as an attack (on the confidentiality and/or integrity of the data or the availability of the machine).

Other threat scenarios can also be identified for the service provider, but these are not considered in this document and are therefore not listed in the table.

The transferred condition monitoring data may form the basis for the service provider’s activities and thus represent one of the central assets for the service provider’s business operations. It is therefore necessary to ensure the confidentiality and in particular the integrity of the data transmitted. This applies to the transmission as well as to the processing and storage of the condition monitoring data.

Table 1: Operator – application scenario and threats

Application scenario	Threat
Condition monitoring	Unauthorised access or manipulation of the condition monitoring data by the operator or an attacker.
	Failure of communication on condition monitoring.
Parameterisation	Access to parameters by an unauthorised person or the operator.
	Impairment of the availability or operational safety of the machine due to manipulated parameters.
	Non-recognisable effects of parameterisation.

The consequences of manipulations are extremely critical for the parameterisation function. There is a risk of the plant being negatively influenced here. This can range from a failure to the endangering of operational safety. The integrity of the data is therefore particularly important.

The transmitted data for parameterisation can also represent knowledge of the service provider worthy of protection, which the operator may not or should not see. In this case, the confidentiality of the data must be guaranteed so as to avoid jeopardising the service provider’s business model.

In the event of an incident, the verifiability of whether and which actions have been taken is of relevance in order to determine the causes, if any, and to avoid consequential damage.

3.3 Requirements for the solution approaches

A possible technical implementation for the realisation of the communication between service provider and operator described above must represent a viable solution both functionally and from the point of view of security. The functional aspects (facilitating communication) and the safety aspects (reducing the resultant risk) must be weighed against each other. In addition, the complexity of the resultant solution must be taken into account, as high complexity can lead to errors, security problems or consequential costs (e.g. high operating or maintenance costs).

The solution should be acceptable from the following points of view:

A1) Enable cross-company communication: the solution must be suitable for creating cross-company communication relationships. In particular, it must be suitable for communicating across different security domains. This includes a solution for cross-company authentication in particular.

A2) Compatibility: the solution should be compatible with existing best practices, network structures, devices and software products from different vendors. In addition to OPC UA, only open and non-proprietary standards should be used, so that different implementations are possible and long-term availability and maintainability are ensured.

A3) Suitability for different network sizes and network topologies: the solution should be scalable for both very large and very small networks. Topological properties such as network segmentation into different zones should also be supported but not forced.

A4) Maintainability and control: the solution should allow both fine-grained access control for individual stakeholders and data, but at the same time enable efficient configuration and maintenance of access control rules. This means that both user rights and firewall rules should be configured transparently and efficiently.

A5) Traceability: accesses and changes to the technical systems involved should be traceable. This means that in the event of an incident it can be traced which data was accessed by whom and which parameters were changed by which participant.

Other functional properties, such as achievable performance (latency or throughput) or real-time capability, can be critical to the viability of a solution. However, these properties often vary due to the hardware and software used or the products used. These properties are not therefore the subject of this paper, as the different solutions at the specification level of the OPC UA standard are considered above all.

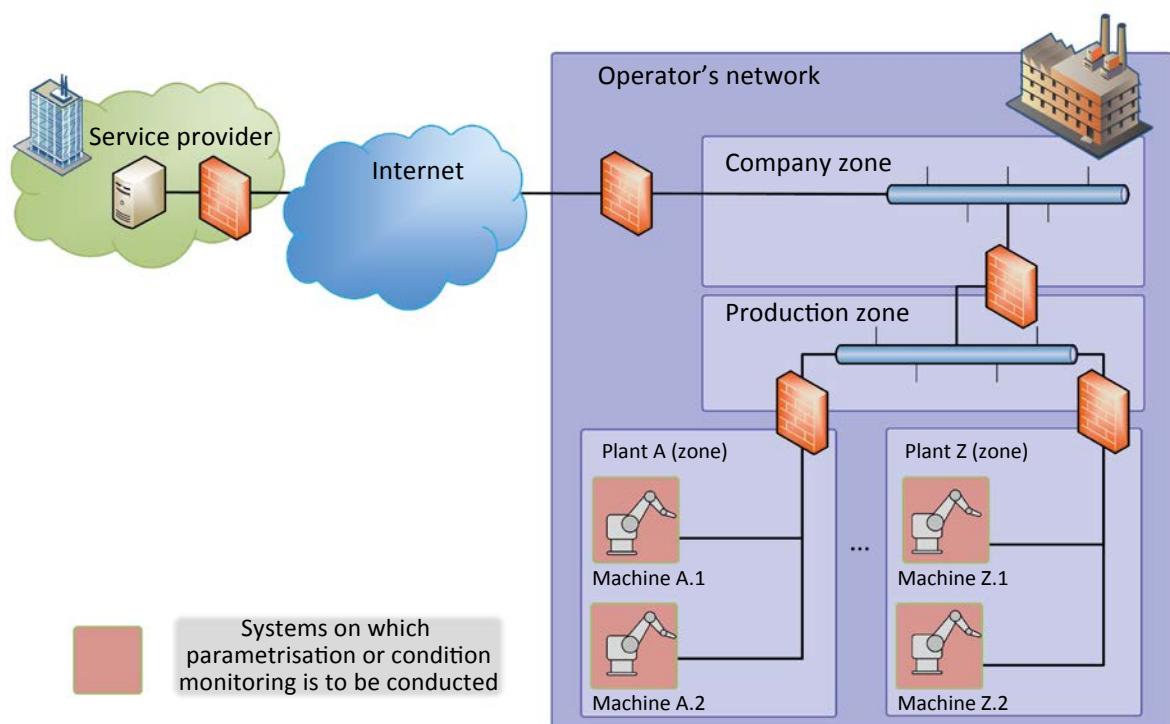


4 Solution approaches

The following sections describe different approaches to a solution. Advantages and disadvantages are explained here. Figure 3 shows a possible implementation for the described

application scenario based on the network architecture of the modular factory. A detailed illustration of the infrastructure on the part of the service provider is not provided here.

Figure 3: Application scenario with service provider and operator



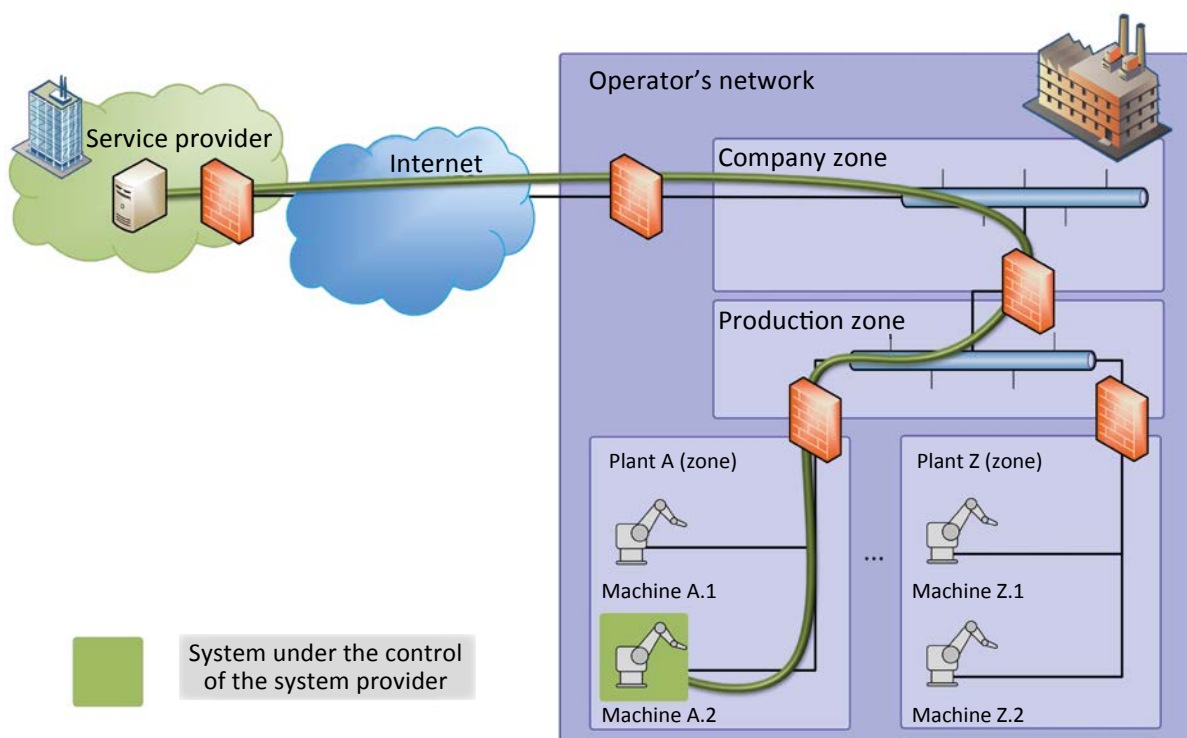
4.1 Solution approach: direct connection

The direct connection is the most technically feasible option. The procedure for establishing a connection between the OPC UA client and the OPC UA server is described for condition monitoring and parameterisation together. The communication takes place directly between the machine and the service provider; see Figure 4. OPC UA offers two variants to implement this.

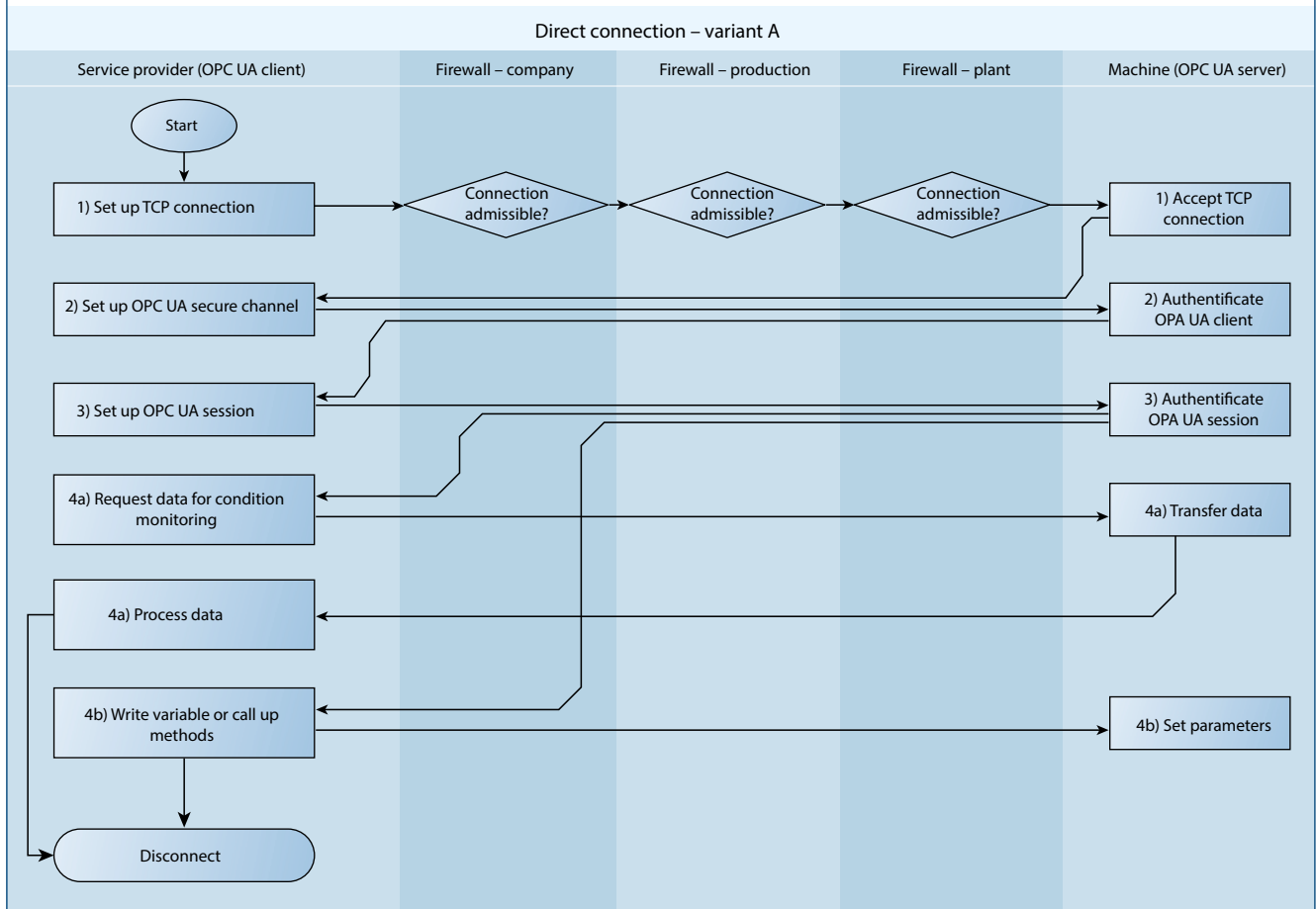
4.1.1 Variant A: client to server

The service provider's OPC UA client connects to the OPC UA server on the machine (see Figure 5). Only authorised access is allowed³.

Figure 4: Network diagram for implementation with direct connection



³ Discussion paper "Zugriffssteuerung für Industrie 4.0-Komponenten zur Anwendung von Herstellern, Betreibern und Integratoren" (10) Section 3.3.

Figure 5: Flowchart of the direct connection setup

The process is as follows:

1. A connection is established from the service provider's OPC UA client to the OPC UA server of the machine. This communication must be authorised and routed through the operator's infrastructure.
2. The OPC UA connection is established. The OPC UA client authenticates the OPC UA server via its certificate. The OPC UA server authenticates the OPC UA client via its certificate.
3. In addition, the user can authenticate himself at the client during the session via (certificate or username+password or token).
The connection is encrypted via the OPC UA mode "Sign and Encrypt" and the exchanged messages are signed. The rights are fixed to the session as they result from the user or connection information.
4. Once the connection has been successfully established, the data can be accessed by the various "Condition Monitoring" (a.) and "Parameterisation" (b.) functions:
 - a) The OPC UA client retrieves data from the machine. Different variants are possible:
 - i) The OPC UA client periodically requests the desired values from the OPC UA server.
 - ii) The OPC UA client registers for a data point and the OPC UA server sends the value to the client periodically or in case of changes.
 - b) The OPC UA client parameterises the machine. To do this, it changes variables in the information model by direct OPC UA write or method requests.

4.1.2 Variant B: reverse-connect

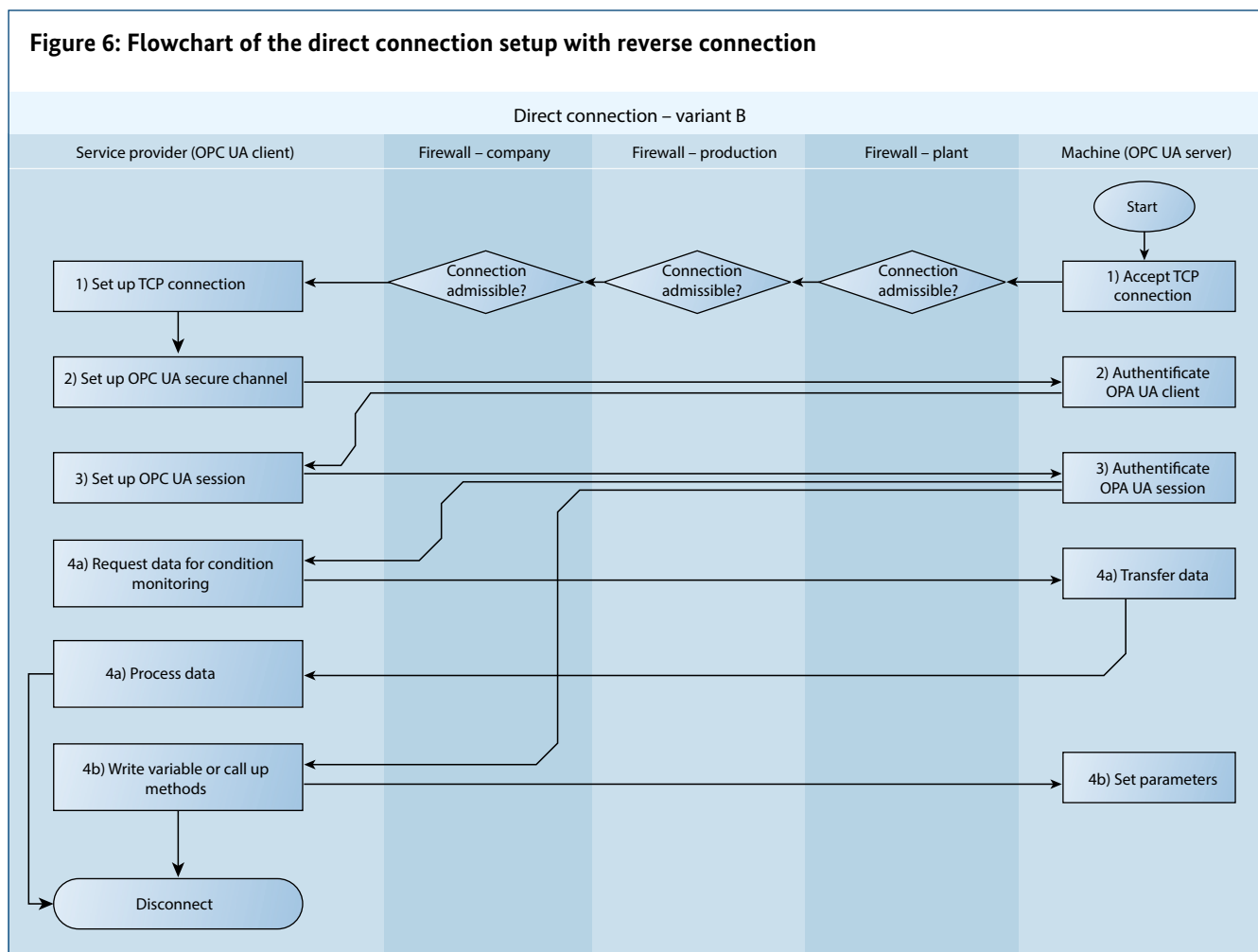
The OPC UA server on the component connects to the service provider's OPC UA client (see Figure 6). Only authorised access is allowed⁴. This variant differs from the previous variant A only in step 1, the direction in which the TCP connection is established.

The authentication, authorisation and access to the data or methods with reverse-connect does not differ from the

normal connection setup in client-server operation and therefore does not have to be considered separately.

The connection setup is initiated by the machine. A reverse connection procedure is used for this purpose. This procedure is described in the OPC UA standard under "Reverse-Hello Message"⁵.

1. A TCP connection is established between the machine's OPC UA server and the service provider's OPC UA client.



⁴ Discussion paper "Zugriffssteuerung für Industrie 4.0-Komponenten zur Anwendung von Herstellern, Betreibern und Integratoren (10) Section 3.3.

⁵ OPC Unified Architecture, Part 6, 1.04, Section 7.1.3 "Establishing a connection".

2. The OPC UA client of the service provider uses this TCP connection to establish an OPC UA connection at the application level to the OPC UA server of the machine. The OPC UA client authenticates the OPC UA server via its certificate. The OPC UA server authenticates the OPC UA client via its certificate.
3. In addition, the user can authenticate himself at the client during the session via [certificate or username+password or token], as in variant A.
4. After the connection has been successfully established, the data accesses of the various functions “Condition Monitoring” (a.) and “Parameterisation” (b.) can be carried out as in variant A.

4.1.3 Process/prerequisites

To be able to establish a connection according to variant A, the standard port (TCP 4840) for incoming connections must be enabled in all of the operator’s firewalls up to the component. The accessibility and addressability of the OPC UA server of the component must be guaranteed by the service provider via appropriate NAT rules or port forwarding at the operator.

- With variant B, it is sufficient if the firewalls in the operator’s network allow connections to the internet to be established. It is possible that the connection is restricted to a specific host or domain of the service provider. The “reverse-connect” protocol (see above) must be implemented according to the OPC UA standard.
- In both cases, these are measures that must be taken into account during deployment. The configuration of firewalls is the responsibility of the operator and is independent of OPC UA.
- The OPC UA connection is authenticated in step 2. The corresponding certificates must be available in the OPC UA server and client for this; see discussion paper “Sichere Implementierung von OPC UA für Betreiber, Integratoren und Hersteller” (Secure implementation of OPC UA for operators, integrators and manufacturers” (2). OPC UA-Trust lists could be established and used for the administration of the issued certificates.

- The established connection can be used to retrieve data from the OPC UA server, to set variables on the server or to request methods. The user logged on to the OPC UA server must be authorised to access the necessary data or methods.

4.1.4 Evaluation

In practice, the choice of the variant to be used has far-reaching consequences for the resulting security or for the complexity of the administration.

The properties of the two variants will therefore be discussed in the following.

4.1.4.1 Variant A: client to server

The advantage of a direct connection is that this variant is the most common method for establishing a connection between OPC UA devices and should therefore be supported by all OPC UA-capable devices. In this sense, requirements A1 and A2, i.e. cross-company communication, are met with the greatest possible compatibility.

On the other hand, there is the disadvantage that direct access to the OT network takes place from external systems, since the component is directly connected to the internet. The implementation of the connection and the enabling in the operator’s network generates expenditure, which increases with increasing number of components of different manufacturers. This is in contrast to requirement A3, the scalability over different network sizes and number of devices.

Incoming connections into the OT network should also be viewed critically, since they can provide an attacker direct access to the components in the production network. As a protective measure, access to individual IP addresses of a service provider can be restricted. However, with an increasing number of service providers, this is associated with an increasing amount of administration, which is contrary to requirement A4, the maintainability and control of communication.

With the „Sign and Encrypt“ security mode, the connection is set up and used end-to-end encrypted. The operator's network-based security mechanisms (e.g. IDS, IPS) are therefore not able to view and monitor the communicated data. Operators often use IP addresses from private areas or assign IP addresses dynamically. It is therefore difficult for the service provider to address the machine in the operator's network. Addressability can be produced by NAT or port forwarding or the use of a „reverse proxy“ in the operator's network and must be maintained. This means that additional work must be taken into account.

These properties also conflict with the objectives A3 and A4, i.e. scalability, maintainability and access control.

Since the OPC UA server in this variant is under the control of the operator, the operator can record which accesses and changes have taken place on the server in a fine-granular way using suitable logging mechanisms. Logging can take place outside the access of the service provider, so that the goal of traceability (A5) can be guaranteed for the operator. In addition, all incoming connections should be logged, but this is not part of the OPC UA server.

4.1.4.2 Variant B: reverse-connect

With this connection variant, only connections originating from the component must be permitted. The response packets of the OPC UA client to the server's reverse-connect connection request are generally allowed by the firewalls. The advantage for the service provider is that access to the data is not restricted. Outgoing connections should nevertheless be monitored and specifically approved by the operator. A positive aspect for the operator is that the effort for approvals in the firewalls is still generally lower compared to variant A. In contrast to variant A, targets A3 (scalability) and A4 (maintainability) are therefore better met. If the production network is located behind a Network Address Translator (NAT), the use of variant B is also simpler, since port forwarding rules (in combination with firewall rules for port forwarding regulation) do not need to be established. This also contributes to better scalability and maintainability (A3 and A4).

On the other hand, the operator's control over communication is limited, because the component can establish connections to the service provider autonomously. A direct connection between an external system and the operator's OT network also exists with this connection variant, so that here too the target A4 (control) can only be regarded as fulfilled to a limited extent. Target A5 (traceability) may also suffer from the autonomous connection of the component to the service provider's servers.

The address of the OPC UA client of the service provider must be configured on the machine. This is scaled in a linear manner for many machines and may cause a lot of work if the OPC UA client is changed or relocated.

It is not possible for the operator to monitor the transmitted data, as they are transmitted end-to-end encrypted. However, logging by the component itself is still possible and serves the purpose of traceability, i.e. target A5. However, if the operator is unable to access the recorded event logs of the component (e.g. because they are configured and managed by the service provider), the objective of traceability cannot be achieved by the operator but only by the service provider. Depending on the access to the log data of the server of the component, the goal of traceability (A5) can be achieved either for the operator, the service provider or both parties.

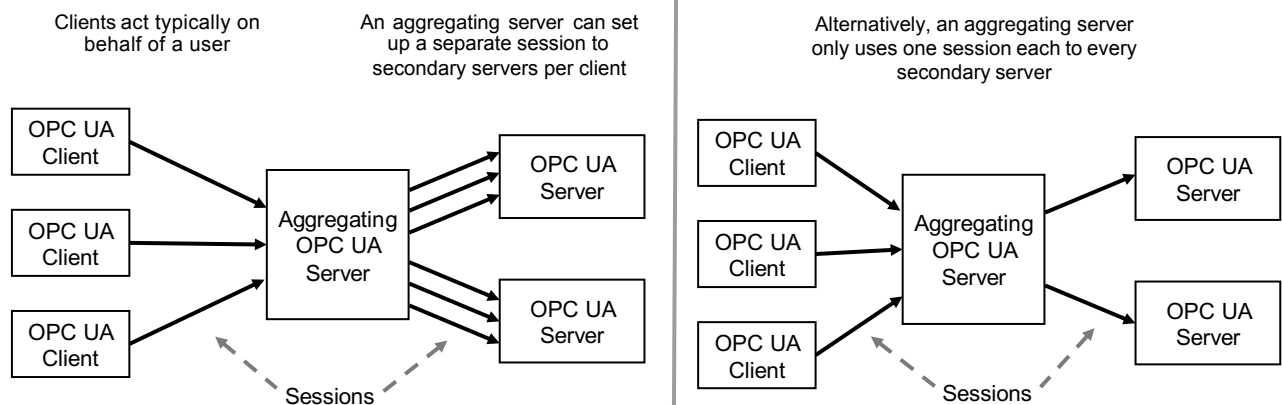
4.2 Solution approach: aggregating server

The OPC UA communication is to take place via an intermediate instance (aggregating server⁶). An aggregating server can serve

- a) as a central access point, which accepts and forwards requests
- b) as a central data concentrator and data supplier, which retrieves information from the secondary sources and provides it in its own (new) information model

It maintains or establishes connections to the OPC UA servers of the secondary components for external OPC UA clients. On behalf of these OPC UA clients, it can forward

⁶ According to the specification of OPC UA this is called „aggregating server“, see *OPC Unified Architecture, Part 4, Release 1.04, Section 5.6.2 „Create Session“* and there especially Figure 14. Inclusion as reference in the final documentation/version.

Figure 7: Different uses of an aggregating server

accesses to OPC UA servers in secondary components. In the case of data access, the option exists of intermediate storage (caching), processing/preparation of the data and adaptation of the aggregated information models.

An aggregating server can only establish one session to each secondary OPC UA server, via which all data accesses take place or are forwarded (Fig. 6, right). Alternatively, an aggregating server can introduce an additional security level by establishing independent sessions for each OPC UA client through which only the data accesses from the respective OPC UA client take place (Figure 7, left).

It is possible to connect several aggregation servers in series (“cascading”).

In addition, the following advantageous aspects of using an aggregating server should be mentioned:

- a) It can reduce the amount of TCP/IP connections passing through firewalls by establishing/maintaining only one connection at a time to the secondary components or other secondary aggregating servers;
- b) It simplifies handling because only one OPC UA server (aggregating server) needs to be addressed from the outside in order to be able to access the data/information models of several secondary components.

An aggregating server can be provided and administered either by the operator or by the service provider, even if - as shown here - it is set up at the operator.

This results in the advantages and disadvantages described below.

4.2.1 Scenario A: the operator provides and manages an aggregating server.

The solution variant is firstly described and discussed here in which the operator sets up, configures, and manages the aggregating server in his environment. He configures the connections that the aggregating server establishes to the components it operates.

The operator grants the service provider access to the aggregating server and the corresponding parts of the information model. The operator may grant various service providers access to the aggregating server, in each case to the relevant parts of the model and thus to the relevant components.

4.2.1.1 Advantages

A positive aspect of the evaluation of this „operator administration“ scenario is that the „proxy“ scenario should al-

The disadvantage for the service provider is that the operator can listen in on condition monitoring and parameterisation and/or manipulate data. This may be unacceptable for some business models (e.g. if the component remains in the possession and control of the service provider).

From the service provider's point of view, this therefore conflicts with the objectives of control (A4) and "confidentiality", especially where sensitive data is exchanged between the service provider and the component. An example of this is the parameterisation of secret formulations or if the information content of the condition data contains intellectual property during condition monitoring.

From the point of view of the service provider, this scenario also has a disadvantage in terms of traceability (A5), since the operator is completely responsible for the ownership of the audit information.

The credentials (logon data such as user name and password) for establishing the connection from the aggregating server to the component must be set by the operator and are therefore known to the operator. The associated rights must allow all access to the components by a service provider through the aggregating server. This may also conflict with the objective of control (A4) by the service provider.

4.2.2 Scenario B: the service providers set up their own aggregating servers at the operator's site.

The second scenario of using an aggregating server is that the service provider sets up, configures and maintains an aggregating server at the operator's site, so that he can connect to it remotely and reach all relevant components using it.

The service provider configures which information models are to be made available from which components in the aggregating server. In particular, the service provider configures which credentials (logon data) the aggregating server uses to establish connections to the secondary components.

4.2.2.1 Advantages

The remote maintenance scenario with third-party components of a service provider is already known to the IT administrators of an operator. Since similar solutions are established in the industrial environment, this integration

can be considered compatible with requirements A1 and A2. By way of improvement, as in the previous scenario, direct connections from the very outside to the very inside do not have to be allowed, but only up to a defined point (the service provider's aggregating server). This supports the achievement of the goal of control and scalability (A3 and A4).

The service provider's installation, configuration and maintenance of the aggregating server can relieve the operator, which in turn contributes to the availability of scalable cross-company communication (requirements A3 and A4).

The service provider continuously determines the security level of the encryption of the communication from its site to the component. The secret of the parameterisation data and the data from the condition monitoring can be kept for the service provider throughout, since the service provider has control over the encryption of the communication of the aggregating server with secondary components and can thus rule out that the operator also reads the communication. From the service provider's point of view, this supports the objectives of control and traceability (A4 and A5).

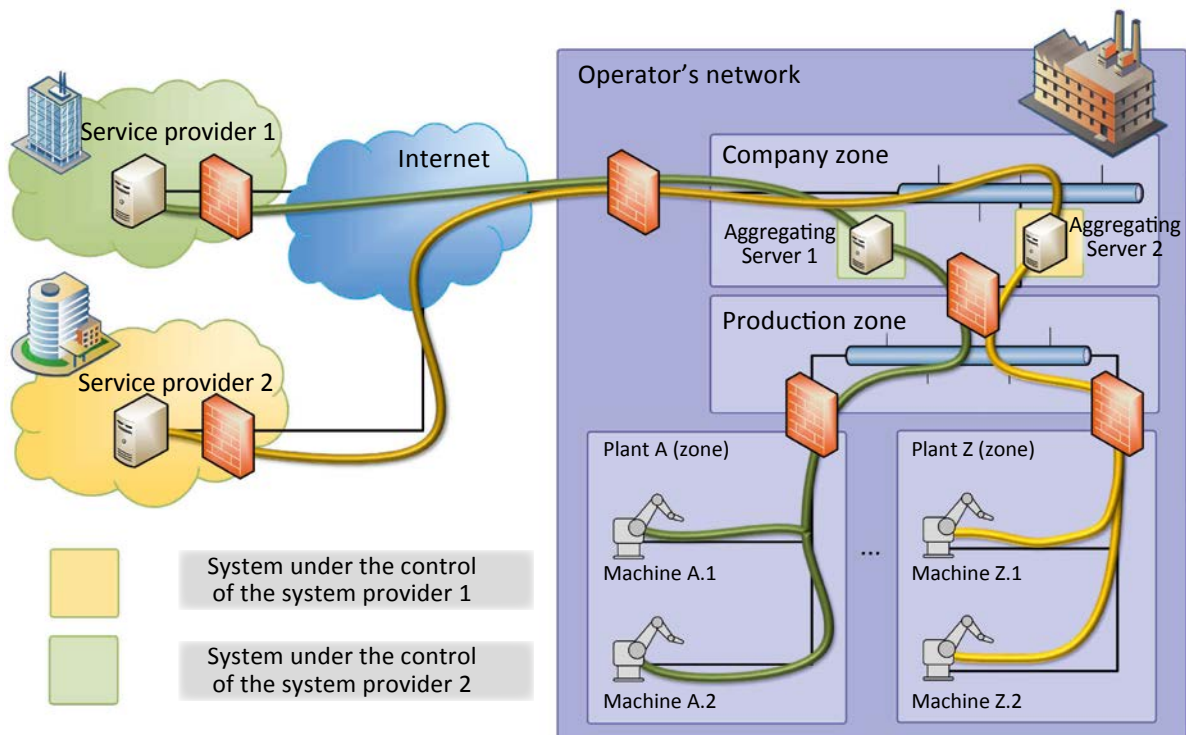
4.2.2.2 Disadvantages

However, the use of this solution also results in disadvantages, especially for the operator. The operator has no control over which information the service provider receives from the components and which parameterisations the service provider makes on the components. In addition, the service provider can remote control unseen components in the operator's network. The operator must therefore have a high degree of trust in the service provider. This stands in the way of the operator's objectives of control and traceability (A4 and A5).

An additional restriction of the communication also leads to increased work on the part of the operator, since external components have to be handled in the own network. This can affect the scalability and maintainability of the network (A3, A4).

The operator must accept the installation of a large number of aggregating servers if components are to be monitored (condition monitoring) and parameterised by different service providers. This is particularly problematical as

Figure 9: Network diagram for the management of the aggregating server by the service providers



the service providers do not have to or cannot be coordinated with each other. If several service providers need access to a larger plant, the complexity of the operator's network increases and impairs the operator's control over what is happening in its own network (requirement A4).

Through the administration of the aggregating server by the service provider, the service provider is given access to the server's event data acquisition and can thus track accesses and changes precisely (requirement A5). The operator is dependent on the cooperation of the service provider in order to also gain access to the logs and to achieve the goal of traceability (A5) for itself.

4.2.3 Evaluation and comparison of scenarios

When using an aggregating server, there are basically two ways of organising the configuration, administration, and operation described above: either by the operator or by the service provider. The person who takes over the administration of the aggregating server always has the work and responsibility for the correct and secure configuration. The

other party saves this work, but must trust the person who administers the aggregating server that the confidentiality and integrity of all data and metadata will not be violated. It should be emphasised that a breach of confidentiality or integrity always requires deliberate intervention and is not the result of a decision in favour of an operational concept alone.

Scenario A with the administration of the aggregating server by the operator makes overall sense if the operator wants complete transparency and control and the service provider is willing to grant it. For the service provider, however, it represents a compromise in terms of maintaining control over the component and maintaining the confidentiality of communication with the component. However, the service provider has to accept that he has to grant rights as well as disclose business secrets, because the operator can read everything.

Scenario A seems to be well suited when different service providers are active for the same operator and also do not object to the operator's access to the data they transmit.

Scenario B, in which a service provider installs and administers an aggregating server at the operator's site, is particularly useful from the service provider's point of view if the service provider seeks to exercise maximum control over the interaction with the component.

However, this scenario is all the more problematical the more service providers are active for the same operator. It therefore works particularly well when one service provider looks after many trustworthy operators and they commission only one service provider in the main.

In addition, it should be mentioned that in both scenarios the "reverse-connect" procedure (especially for the connections between the aggregating server and the secondary OPC UA servers of the components) can be used, which brings an additional level of security, since the firewalls then always have to be crossed in the usual direction.

4.3 Comparison of solution approaches

The operator and service provider must decide on which of the variants described above, direct connection or aggregating server, is to be used. Care must be taken to ensure that future extensions of plants, including components from other manufacturers, are also taken into consideration. From the security point of view, the administration and monitoring of a large number of direct connections in everyday operation, such as scalability (A3), control (A4) and traceability (A5), do not appear realistic. In addition, the operator must introduce a corresponding access con-

trol in a way that is outside of the OPC UA communication, to protect against untimely parameterisation. This can be done, for example, using a key-operated switch on the component or plant with which the parameterisation can be enabled for a limited period of time. This applies in particular, in accordance with the control requirements (A4), where there is a risk of danger to life and limb during parameterisation work.

Regardless of the operating concept, the use of an aggregating server simplifies access to several components: the number of necessary connections (with appropriate zoning of the network also by firewalls) is reduced. The consistent use of OPC UA means that the information model of the components is not lost; rather, it is represented on the aggregating server and can be supplemented by the information models and data of other components if necessary. Changing the operating concept for the aggregating server(s) is more time-consuming. This includes the exchange of hardware and software as well as the necessary processes for operation and maintenance. If the operation of the aggregating server rests with the operator, he can restrict the write access for the parameterisation via the settings. Due to possible hazards for machine operators, further measures should be taken, such as a key-operated switch on the machine.

The "reverse-connect" procedure extends the possibilities for establishing a connection between OPC UA client and server. This makes it possible to also operate an OPC UA server behind a firewall, the function of which would otherwise prevent a client from establishing a connection.



5 Summary and outlook

The document discusses solutions for cross-company communication with OPC UA based on the client-server concept. The information flow can only be controlled by using the “aggregating server” solution. From the point of view of an operator who is responsible for his security domain, only the in-house operation of an aggregating server can be considered.

One problem of the aggregating server, as with many other proxy solutions, is that the connection between client and server is broken and the protection of authenticity, as it would be possible with end-to-end connections, is lost. The extent to which it is possible to supplement the concept in order to achieve this goal, or whether the application of the publish-subscribe model offers a solution here, should be examined.

In addition to the client-server connection method described in this document, OPC UA also offers the possibility to communicate using the Publish Subscribe model or PubSub for short. In addition to the primary advantage of

higher performance or lower hardware requirements due to the use of connection-free protocols (UDP), PubSub can also be used to set up other communication structures.

The client-server architecture described in this document is based on 1:1 connections per se. This also applies when using an aggregating server which, as shown, can simultaneously establish and maintain several 1:1 connections. In contrast, PubSub defines a 1:n or “one to many” communication in which a component (publisher) distributes its data to several recipients (subscribers). Since publish-subscribe communication is subject to different requirements, both from the point of view of the communication layer in the network and in terms of topology, this communication procedure is not considered in this document and will be discussed in a future document.

6 Attachment

6.1 Glossary

Authentication	The process of verifying the identity of a person or a computer system on the basis of a particular characteristic.
Authentication	Authentication refers to the verification or examination of authenticity.
Authorisation	Authorisation checks whether a person, IT component, or application is entitled to perform a specific action.
ABAC	Attribute Based Access Control
Credentials	Logon data such as user name and password for use in authentication/authentication
Security domain	Technologically, organisationally or spatially contiguous area with uniform security requirements and/or uniform security administration.
TLS	Transportation Layer Security
Zones and conduits	Concept of IEC 62443 (7) for subdividing automation systems into zones with different security requirements and coupling them, for example by means of firewalls (zones and conduits)

6.2 List of figures

Figure 1: Exemplary consideration of communication relationships on the communication and information layer in RAMI4.0	4
Figure 2: „Condition Monitoring and Parameterisation“ application scenario	8
Figure 3: Application scenario with service provider and operator	11
Figure 4: Network diagram for implementation with direct connection	12
Figure 5: Flowchart of the direct connection setup	13
Figure 6: Flowchart of the direct connection setup with reverse connection	14
Figure 7: Different uses of an aggregating server	17
Figure 8: Network diagram for establishing communication via aggregating server	18
Figure 9: Network diagram for the management of the aggregating server by the service providers	20

6.3 Bibliography

1. *Diskussionspapier „Sichere Kommunikation für Industrie 4.0“*. Berlin: Plattform Industrie 4.0, 2017.
2. *Diskussionspapier „Sichere Implementierung von OPC UA für Betreiber, Integratoren und Hersteller“*. Berlin: Plattform Industrie 4.0, 2018.
3. *Technischer Überblick „Sichere unternehmensübergreifende Kommunikation“*. Berlin: Plattform Industrie 4.0, 2016.
4. *Umsetzungsstrategie Industrie 4.0*. Berlin/Frankfurt: Plattform Industrie 4.0, 2015.
5. *Welche Kriterien müssen Industrie 4.0 Produkte erfüllen?* Frankfurt/Main: ZVEI, 2016.
6. Information technology – Security Techniques – Information Security Management System. *ISO/IEC 27000:2014*.
7. Security for industrial automation and control systems. *IEC 62443*.
8. Information technology – Security techniques – Code of practice for information security controls based on ISO/IEC 27002 for cloud services. *ISO/IEC 27017:2015*.
9. Information technology – Security techniques – Information security for supplier relationships. *ISO/IEC 27036*.
10. *Diskussionspapier „Zugriffssteuerung für Industrie 4.0-Komponenten zur Anwendung von Herstellern, Betreibern und Integratoren“*. Berlin: Plattform Industrie 4.0, 2018.

EDITORIAL TEAM

Carsten Angeli, KUKA Roboter GmbH | Dr. Hans-Peter Bock, TRUMPF Werkzeugmaschinen GmbH & Co. KG | André Braunmandl, Bundesamt für Sicherheit in der Informationstechnik | Torsten Förder, PHOENIX CONTACT Software GmbH | Prof. Dr. Tobias Heer, Hirschmann Automation & Control GmbH, Hochschule Albstadt-Sigmaringen | Dr. Christian Haas, Fraunhofer IOSB | Dr. Detlef Houdeau, Infineon Technologies AG | Dr. Lutz Jänicke (Leitung), PHOENIX CONTACT GmbH & Co. KG | Jens Mehrfeld, Bundesamt für Sicherheit in der Informationstechnik | Florian Patzer, Fraunhofer IOSB | Andreas Pfaff, Mitsubishi Electric Europe B.V. | Tobias Pfeiffer, Festo AG & Co. KG | Julius Pfrommer, Fraunhofer IOSB | Wolfgang Stadler, SICK AG | Detlef Tenhagen, HARTING Stiftung GmbH & Co. KG | Dmitry Tikhonov, Expleo Germany GmbH | Thomas Walloschke, Fujitsu Technology Solutions GmbH

